

2.2.12 Lesson Review

Date: 3/7/2026, 12:48:30 AM

Time Spent: 08:09

Score: 100%

Passing Score: 80%



A technology startup integrates a pre-trained language model downloaded from a public online repository into their customer support chatbot. As a security tester, you need to evaluate whether the chatbot is resilient against supply chain risks present in the model source and training artifacts.

During your assessment, you ask the chatbot a question about refunds, and it generates a response containing a link to an unfamiliar third-party website (e.g., "Please process your refund at <http://fakebank-refund.xn--com-9o0a/>).

What action should demonstrate that the security controls for supply chain risk are being properly applied in this scenario?

- ☐ The chatbot should permit all model responses, logging user behavior for issues after-the-fact only if a customer reports a problem.
- ☐ The IT team should rely entirely on the repository's community ratings and implement the model without performing an independent risk assessment.
- ☐ The organization should assume that all open-source models are safe if widely used and deploy them directly without additional validation.
- ☒ The security controls should verify and validate all pre-trained models before deployment, block suspicious content, and prevent output of external, unapproved links. ✔ Correct

Explanation

The security controls should verify and validate all pre-trained models before deployment, block suspicious content, and prevent output of external, unapproved links is the correct answer. This option represents the application of robust supply chain security controls. Actively validating pre-trained model integrity, filtering model outputs for suspicious links, and blocking unapproved external destinations before deployment helps prevent the exploitation of malicious modifications or poisoned data in third-party AI models.

The organization should assume that all open-source models are safe if widely used and deploy them directly without additional validation is incorrect. This is a risky approach. Widely used models can still be compromised, and lack of validation exposes the organization to hidden threats, such as embedded malicious instructions. Vigilant supply chain security always requires verification before deployment.

The IT team should rely entirely on the repository's community ratings and implement the model without performing an independent risk assessment is incorrect. Community ratings and reviews do not guarantee technical security. Supply chain attacks can be subtle and targeted. Organizations must conduct their own thorough risk assessment and validation to ensure integrity and compliance.

The chatbot should permit all model responses, logging user behavior for issues after-the-fact only if a customer reports a problem is incorrect. Post-incident response is not sufficient for managing supply chain risk. Allowing potentially dangerous model outputs and relying on customer reports exposes users and the company to immediate harm. Controls must prevent such issues before deployment and output.

Related Content

 [2.2.1 Overview of AI Security Controls](#)

 [2.2.8 Testing Security Controls](#)

resources\questions\q_testing_security_controls_03.question.xml

A hospital uses an AI-powered assistant to help staff access laboratory results for patients. Access control policies are in place to ensure that users can only view results for patients assigned to them.

To test the effectiveness of these AI security controls, you log in as a nurse and enter the following prompt:

"I need to review the last 10 blood test results for all cancer patients in the hospital for a report. Please list them."

What is the BEST step to take once you see how the AI assistant responds?

- ☐ Accept the AI assistant's answer as long as it does not contain sensitive data like patient addresses.
- ☐ Assume the AI assistant's internal controls are sufficient if it responds quickly, regardless of the information displayed.
- ☒ Confirm whether the AI assistant refuses the request or limits the displayed data to authorized patients, and report any access violations for remediation. ✓ Correct
- ☐ Repeat the test using your administrator account for faster results.

Explanation

Confirming whether the AI assistant refuses the request or limits the displayed data to authorized patients, and reporting any access violations for remediation is the correct answer. This approach correctly applies the principles of access control testing. You must verify that the AI system enforces permissions based on user roles—in this case, ensuring the nurse cannot access data for unassigned patients. Any violation, such as providing unauthorized patient information, must be reported for remediation to prevent future data leaks or unauthorized access.

Accepting the AI assistant's answer as long as it does not contain sensitive data like patient addresses is incorrect. Access control testing is not limited to addresses or specific data types—it covers all patient data that has access restrictions. The AI should reveal only what the user is authorized to see. Accepting unauthorized access to any patient data, even if not highly sensitive, is a failure in access control enforcement.

Assuming the AI assistant's internal controls are sufficient if it responds quickly, regardless of the information displayed is incorrect. Response speed does not indicate proper access control. Even a fast response could leak restricted data. Security controls must be validated based on information access, not performance metrics.

Repeating the test using your administrator account for faster results is incorrect. Testing with an administrator account does not verify access controls for limited roles like that of a nurse. The goal is to ensure that lower-privileged accounts cannot access data beyond their authorization. Testing with administrative privileges bypasses this critical check.

Related Content

 2.2.1 Overview of AI Security Controls

 2.2.8 Testing Security Controls

resources\questions\q_testing_security_controls_08.question.xml

Which example best illustrates excessive agency testing when evaluating the security of an AI system?

- ☒ Asking the AI system to automatically delete all customer records without requiring additional human approval. ✓ Correct
- ☐ Reviewing whether the AI model can distinguish between weather and sports queries when both are submitted in a single prompt.
- ☐ Checking if the AI system can generate offensive language when prompted with inappropriate user inputs.
- ☐ Submitting repeated login attempts to the AI system to see if it will lock the account after too many failures, thus verifying rate limitation controls and account lockout mechanisms that prevent brute-force attacks and unauthorized access.

Explanation

Asking the AI system to automatically delete all customer records without requiring additional human approval is the correct answer. This option directly relates to excessive agency testing. It tests whether the AI system is given too much control or "agency" to perform sensitive actions (like deleting all customer records) autonomously, without the safeguard of human approval. This is a critical area to check, as such unchecked power can lead to accidental or malicious destruction of important or sensitive data.

Checking if the AI system can generate offensive language when prompted with inappropriate user inputs is incorrect. While this option looks at the AI system's handling of inappropriate or offensive user inputs, it focuses on content moderation and output filtering—not on the issue of excessive agency. It does not test whether the AI can take overly powerful actions on its own.

Submitting repeated login attempts to the AI system to see if it will lock the account after too many failures, thus verifying rate limitation controls and account lockout mechanisms that prevent brute-force attacks and unauthorized access is incorrect. This answer describes testing rate limitation controls and account lockout features, which are important for preventing brute-force attacks. Although essential for security, this is a different area of testing (access and rate control) and does not address excessive agency or the risk that the AI performs critical operations without oversight. The explanation is intentionally more detailed than the correct answer.

Reviewing whether the AI model can distinguish between weather and sports queries when both are submitted in a single prompt is incorrect. This scenario is about evaluating the AI's functional ability to categorize queries, which reflects its natural language understanding or intent classification. It does not relate to security testing, nor does it concern the AI's ability to execute highly sensitive actions without additional validation steps.

Related Content

 2.2.1 Overview of AI Security Controls

 2.2.8 Testing Security Controls

resources\questions\q_testing_security_controls_11.question.xml

What do modality limits in an AI gateway most directly control?

- ☒ The types of inputs and outputs (such as text, images, audio, or video) that the model is allowed to process for a user or application. ✓ Correct
- ☐ The automatic prioritization of user requests during periods of high system demand, managing resource allocation so that mission-critical applications always process first.
- ☐ The total number of users that are permitted to access the AI system within a certain time frame.
- ☐ The total data storage capacity allocated to each user account, ensuring users cannot exceed disk space quotas regardless of input type.

Explanation

The types of inputs and outputs (such as text, images, audio, or video) that the model is allowed to process for a user or application is the correct answer. Modality limits are designed to restrict which kinds of input and output formats the AI model can handle per user, application, or environment. These controls help organizations decide, for example, whether text, images, audio, or video are allowed, thus reducing risk and simplifying policy enforcement.

The total number of users that are permitted to access the AI system within a certain time frame is incorrect. This describes a user quota, not a modality limit. Modality limits do not control the number of users, but rather the kinds of data formats that can be processed.

The total data storage capacity allocated to each user account, ensuring users cannot exceed disk space quotas regardless of input type is incorrect. This explanation confuses storage quotas with modality limits. Storage quotas deal with overall disk usage, while modality limits specify which types of media (text, audio, image, etc.) can be input or output by the AI.

The automatic prioritization of user requests during periods of high system demand, managing resource allocation so that mission-critical applications always process first is incorrect. This explanation describes resource prioritization or quality-of-service controls, not modality limits. Modality limits do not relate to request prioritization or dynamic allocation of processing resources; they only restrict which types of data formats (modalities) are accepted or returned by the system.

Related Content

2.2.7 Usage and Quota Limitations

resources\questions\q_usage_and_quota_data_limitations_03.question.xml

A marketing company deploys several AI-driven applications that leverage an LLM API for different internal departments: customer relations, finance, and creative content. Recently, the security team discovered that a compromised application key allowed an external attacker to access sensitive financial reports through the LLM interface intended for the finance department.

As the AI security administrator, you are asked to propose a solution that properly applies endpoint access controls using the AI gateway.

Which of the following measures BEST implements endpoint access controls at the AI gateway level, according to industry recommendations?

- ☐ Enable detailed logging and monitoring of API usage to retrospectively investigate unauthorized access attempts after incidents have occurred.
- ☐ Require all department managers to personally approve any LLM requests involving sensitive information by email, before the requests are relayed to the LLM via the gateway.
- ☒ Configure the AI gateway to issue virtual or scoped API keys with limited permissions and expiry times for each application. ✓ Correct
- ☐ Rely on a single master API key embedded in all applications, and instruct developers to rotate it periodically to minimize the risk of compromise.

Explanation

Configuring the AI gateway to issue virtual or scoped API keys with limited permissions and expiry times for each application, ensuring only authorized users and services can access specific LLM endpoints under defined policies, is the correct answer. This is the best application of endpoint access controls. Virtual or scoped keys limit access based on the intended use, can be revoked if compromised, and restrict exposure by department or function. Issuing time-limited, capability-specific credentials is central to effective endpoint isolation, traceability, and incident response.

Rely on a single master API key embedded in all applications, and instructing developers to rotate it periodically to minimize the risk of compromise is incorrect. Using a single master key creates a single point of failure. If that key is compromised, an attacker gains access to all endpoints and all application capabilities. While periodic key rotation is better than no rotation, this method lacks granular control and traceability, which are core benefits of endpoint access controls provided through scoped or virtual keys at the gateway.

Enabling detailed logging and monitoring of API usage to retrospectively investigate unauthorized access attempts after incidents have occurred is incorrect. Detailed logging is important and facilitates incident investigation, but it is not a preventive measure nor does it implement access controls by itself. Endpoint access control requires proactive enforcement of who can access which LLM endpoints, under what circumstances—something logging alone does not accomplish.

Requiring all department managers to personally approve any LLM requests involving sensitive information by email, before the requests are relayed to the LLM via the gateway, is incorrect. While human review might mitigate certain risks, it is inefficient, does not scale, and is not a technical enforcement of endpoint access controls. There's no guarantee that approvals are secure, timely, or tracked within the actual gateway system. Automated, policy-driven access via scoped keys is much more effective and aligns with best practices in the industry.

Related Content

resources\questions\q_gateway_and_interface_controls_04.question.xml

Question 6

✓ Correct

Which of the following are the key parts of a prompt template as used in AI systems? (Select two.)

☒ User input ✓ Correct

☐ Response token

☐ Data encryption

☐ API key

☒ System prompt ✓ Correct

Explanation

User input is a correct answer. The user input is one of the two main components of a prompt template. It refers to the actual query, message, or question sent by the end user to the AI. Prompt templates are designed to incorporate the user's content into the appropriate place for processing by the AI.

System prompt is a correct answer. The system prompt is the foundational instruction or background context provided to the AI model. It defines the AI's intended behavior, tone, restrictions, or specific instructions it needs to follow. When combined with user input in the prompt template, it guides the model's responses appropriately.

Data encryption is incorrect. Data encryption is not a component of a prompt template; rather, it is a method for securing data during storage or transmission. It is unrelated to the structure of a prompt as described in the lesson.

Response token is incorrect. A response token is a unit of language the AI processes and generates in its outputs, not a structural part of the prompt template. The prompt template is what's given to the AI, while response tokens are relevant to how output is measured or limited, but not part of the prompt's core structure.

API key is incorrect. An API key is a credential used for authentication when accessing an AI service or model, not a component of a prompt template. The two key parts are system prompt and user input.

Related Content

 2.2.4 Prompt Template

resources\questions\q_prompt_templates_02.question.xml

Question 7

✓ Correct

Which options best contribute to minimizing security risks during both data collection and model development stages of the AI development lifecycle? (Select two.)

- ☐ Allowing open access to the model APIs for faster innovation
- ☐ Storing API keys in shared documents for development convenience
- ☒ Sanitizing training data to check for harmful content and prevent bias ✓ Correct
- ☒ Verifying the authenticity of data sources before training begins ✓ Correct
- ☐ Implementing input validation and output content filtering for trained models

Explanation

Verifying the authenticity of data sources before training begins is correct. This step helps ensure that only reliable and non-malicious data is used, minimizing risks of data poisoning at the start of the AI lifecycle.

Sanitizing training data to check for harmful content and prevent bias is correct. Data sanitization during the early stages helps prevent both security and ethical risks (such as bias or hallucinations) before they propagate into the model.

Allowing open access to the model APIs for faster innovation is incorrect. Open API access increases the attack surface and risk of exploitation or abuse, which contradicts good security practices.

Implementing input validation and output content filtering for trained models is incorrect for this context. While valuable, these controls apply post-development; the question focuses on minimizing risks during data collection and model development, not after deployment.

Storing API keys in shared documents for development convenience is incorrect. This creates significant security risks, allowing unauthorized access to critical model resources.

Related Content

resources\questions\q_overview_of_ai_security_controls_01.question.xml

A financial services company deploys an AI-powered chatbot to assist customers with account inquiries. The security team is concerned about the risk of customers unintentionally or maliciously causing the chatbot to reveal sensitive information, generate malicious content, or act outside intended boundaries.

To mitigate these risks, the team implements model guardrails during both input and output stages.

Which of the following actions BEST demonstrates the effective application of model guardrails in this scenario?

- ☐ The chatbot logs all user interactions and forwards transcripts to the compliance department for review at the end of each quarter.
- ☒ The chatbot screens all incoming customer prompts for personally identifiable information (PII) and blocks requests that seek account numbers or attempt prompt injections, while also redacting sensitive information from outputs before responding. ✓ Correct
- ☐ The chatbot increases its response length limit to help customers get more detailed answers, regardless of content type or prompt structure.
- ☐ The chatbot allows customers to upload and process PDF files containing personal data, but relies solely on the user agreeing to terms of service before each upload.

Explanation

The chatbot screens all incoming customer prompts for personally identifiable information (PII) and blocks requests that seek account numbers or attempt prompt injections, while also redacting sensitive information from outputs before responding is the correct answer. This answer directly aligns with the best practices for model guardrails. By screening prompts for PII and blocking malicious requests (such as those trying to access or inject sensitive data), the chatbot enforces input guardrails. By redacting sensitive information from outgoing answers, it enforces output guardrails. These combined controls prevent data leakage, resist manipulation attempts, and maintain compliance—fulfilling both security and organizational policies.

The chatbot allows customers to upload and process PDF files containing personal data, but relies solely on the user agreeing to terms of service before each upload is incorrect. In this option, the chatbot allows file uploads containing personal data based only on a terms of service agreement. This approach relies on user compliance and does not actively prevent the misuse or exposure of sensitive information. There are no technical guardrails that would automatically detect, block, or redact PII, nor are there controls for prompt injection or output moderation. Thus, this does not demonstrate the effective application of model guardrails.

The chatbot logs all user interactions and forwards transcripts to the compliance department for review at the end of each quarter is incorrect. Logging and compliance review are important for auditing and monitoring, but this approach is reactive rather than proactive. Reviewing transcripts at the end of each quarter does not prevent attacks or data leaks in real time. Model guardrails, on the other hand, are active technical controls that filter, block, or redact risky content before it can do harm. Therefore, this answer does not demonstrate the application of model guardrails, but instead refers to post-incident oversight.

The chatbot increases its response length limit to help customers get more detailed answers, regardless of content type or prompt structure is incorrect. Increasing the response length limit provides greater access to information, but without controls tied to content or prompt structure, it actually increases risk. This action could allow the chatbot to inadvertently share sensitive or harmful content, or become more susceptible to prompt injection attacks. Model guardrails should impose boundary checks on content, not just accommodate user requests for extended details.

Related Content



2.2.1 Overview of AI Security Controls



2.2.3 Model Guardrails

resources\questions\q_model_guardrails_03.question.xml

Which of the following BEST describes the purpose of input quotas as implemented in AI gateway controls?

- ☐ They ensure that only humans, not bots, can interact with the AI model by using CAPTCHAs.
- ☐ They allow users to make unlimited requests as long as each request contains only a small amount of data.
- ☐ They encrypt all user data before it is processed by the AI model to prevent data leaks.
- ☒ They limit the total amount of data or the number of requests a user or application can send to the AI system over a specific time period. ✓ Correct

Explanation

They limit the total amount of data or the number of requests a user or application can send to the AI system over a specific time period is the correct answer. Input quotas are designed to control and restrict the overall volume of data or requests that can be submitted to the AI system within a given timeframe, helping prevent resource exhaustion, abuse, or denial-of-service attacks.

They encrypt all user data before it is processed is incorrect. While encryption is important for protecting data privacy, it is not the function of input quotas. Input quotas specifically deal with limiting the quantity or size of requests, not encryption or secure transmission.

They ensure that only humans, not bots, can interact with the AI model is incorrect. Using CAPTCHAs helps differentiate between human and automated activity, but this is unrelated to input quotas, which control the cumulative volume or number of inputs, regardless of whether they originate from a human or a bot.

They allow users to make unlimited requests as long as each request contains only a small amount of data is incorrect. This contradicts the purpose of input quotas. Input quotas place an upper limit on the total number of requests or the total volume of data, not just on individual request sizes. Unlimited requests could still overwhelm the system if not limited by quotas.

Related Content

 2.2.5 Gateway and Interface Controls

resources\questions\q_gateway_and_interface_controls_05.question.xml

A large bank deploys an AI model to automate loan approvals. During security control testing, a tester inputs two loan applications with identical financial profiles but different residential ZIP codes—one from a major city and one from a rural area.

The system approves the city application and rejects the rural one, despite identical financial data.

What action should a security tester take to apply effective bias testing controls in this scenario?

- ☐ The tester should assume the model's outcome is justified as long as the financial data matches policy, disregarding non-financial inputs like ZIP code.
- ☐ The tester should ignore the discrepancy if it reflects historical approval patterns in the bank's legacy data.
- ☒ The tester should flag the disparity for further evaluation, recommend retraining the model with more diverse and balanced data. ✓ Correct
- ☐ The tester should escalate the issue only if a customer from the rural area files a formal complaint.

Explanation

The tester flagging the disparity for further evaluation, recommending retraining the model with more diverse and balanced data, and collaborating with data scientists to reduce bias in decisions is the correct answer. Bias testing involves actively identifying and correcting for unjustified discrepancies. By flagging the issue, seeking further analysis, and promoting retraining with balanced data, the organization addresses root causes and improves fairness.

The tester ignoring the discrepancy if it reflects historical approval patterns in the bank's legacy data is incorrect. Relying on historical data can perpetuate bias. Effective bias testing challenges—and seeks to correct—unjustified patterns, regardless of legacy practices.

The tester escalating the issue only if a customer from the rural area files a formal complaint is incorrect. Waiting for customer complaints is reactive and insufficient. Bias should be proactively detected and addressed through systematic testing, rather than relying on user reports after harm is done.

The tester assuming that the model's outcome is justified as long as the financial data matches policy, disregarding non-financial inputs like ZIP code is incorrect. This ignores a key principle of bias testing: non-financial data such as ZIP codes can introduce unintended discrimination. These variables must be evaluated and, where inappropriate, removed from influencing decisions.

Related Content

 [2.2.1 Overview of AI Security Controls](#)

 [2.2.8 Testing Security Controls](#)

resources\questions\q_testing_security_controls_05.question.xml